triagent

AUTONOMOUS CYBER DEFENSE BENCHMARK REPORT

Triagent: Investigation Results — 10 Test Scenarios

Empirical evaluation of an autonomous, human-in-the-loop AI security analyst investigating simulated Windows attacks and administrative false positives.

AUTHOR

Triagent Security Research Team

DATE

November 3, 2026

FOUNDATION MODELS

Azure OpenAI (Investigation & Agent Core)

TARGET ENVIRONMENT

Windows 10/11 • Sysmon • Sigma Rules

1. Executive Summary & Scope

This report documents the performance of **Triagent**, an autonomous AI security analyst running locally on Windows endpoints to triage, investigate, and remediate security alerts. Operating under a strict "ask-before-acting" paradigm, Triagent inspects operating system telemetry generated by Microsoft-Windows-Sysmon and matched by open-source Sigma detection rules.

The agent is granted access to specialized tools divided into four operational categories:

- **Investigation:** Live process trees (`get_process_tree`), descendant execution tracking (`get_children`), process creation telemetry (`get_events_for_process`), process liveness checks (`is_process_running`), network socket discovery (`get_live_connections`), hash prevalence lookups (`get_events_by_hash`), and historical event correlation windows (`get_events_in_window`).
- **Enrichment:** Cryptographic file verification (`get_file_info`), digital signature validation (`get_file_signature`), VirusTotal global hash reputation (`lookup_hash`), Exa technical intelligence (`exa_search`), and Sigma detection rule logic context (`get_rule_context`).
- **Response:** High-integrity process termination (`kill_process`) and secure forensic quarantine (`quarantine_file`).
- **Communication:** Interactive Human-in-the-Loop (HITL) structured questioning (`ask_user`), operator messaging (`respond`), and formal verdict submission (`submit_verdict`).

> **Benchmark Limitation Note:** This evaluation comprises exactly 10 single-run scenarios (5 simulated attacks and 5 benign administrative activities); it is a controlled proof-of-concept assessment and makes no statistical significance claims.

2. Evaluation Methodology

All tests were conducted on an active Windows desktop workstation instrumented with Microsoft-Windows-Sysmon and an in-memory rule engine evaluating SigmaHQ detection rules. Each scenario was triggered through a dedicated PowerShell harness.

The term **"simulated"** denotes that attack techniques replicated genuine adversary command-line invocations, LOLBin behaviors, and persistence mechanics while using benign dummy targets (e.g. text markers, calculator invocations, or self-contained folders) to preserve system integrity. All human-in-the-loop operator confirmations were scripted and truthful, reflecting the real intentions of the user during each scenario.

Scoring Rule (applied verbatim):

- **Attacks:** *Yes* = verdict matched expected on the scored alert; *No* = it did not; *Partial* = different alerts of the same attack disagreed.
- **Benign:** *Yes* = agent said `false_positive` (correctly cleared); *No* = agent said `true_positive` (wrongly escalated).
- **Partial Scoring Formula:** To ensure objective accuracy, partial outcomes are weighted at 0.5: `attack_accuracy = (count(yes) + 0.5 * count(partial)) / attacks_total = (3 + 0.5 * 1) / 5 = 70.0%`. Benign resolution is evaluated independently (5 / 5 = 100.0%) and not averaged into attack accuracy.

3. Section A — Attack Scenarios

A1

Spearphishing Trojan Dropper (.pdf.exe)

Sigma: Suspicious Double Extension File Execution (high) • 1 Alert

T1204.002 User Execution: Malicious File

T1547.001 Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder

WHAT A REAL ATTACKER WOULD DO

An accounting employee receives a targeted email with an attachment named `Invoice_Payment_Due.pdf.exe`. Because Windows hides file extensions by default, it appears simply as `Invoice_Payment_Due.pdf` with a PDF icon. The user double-clicks it expecting an invoice.

In a real-world intrusion, the executable presents a decoy PDF while silently dropping a secondary payload into `%TEMP%` or `%APPDATA%`, establishes reboot persistence via `HKCU\...\Run`, and connects outbound to an external Command & Control (C2) server to dump credentials and move laterally.

WHAT TRIAGENT DID

Triagent investigated the process lineage and identified a disguised Windows binary named Invoice_Payment_Due.pdf.exe running from the Downloads directory. The agent verified the binary signature, queried the user via HITL to confirm the execution was unauthorized, and obtained operator approval to terminate the running process. It then quarantined the disguised executable from the Downloads folder, successfully neutralizing the active threat before concluding true positive.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
3m	409,285	$0.1637

✓ Outcome: Yes (Matched Expected Verdict)

Triagent correctly classified the disguised executable as a true positive attack. Through HITL intervention, the agent successfully terminated the rogue process and quarantined the dropper, though persistence registry keys and dropped temp scripts were left as documented remaining risks.

A2

Ingress Tool Transfer via Certutil

Sigma: Suspicious File Downloaded From Direct IP Via Certutil.EXE (high) • 3 Alerts

`T1105` Ingress Tool Transfer

WHAT A REAL ATTACKER WOULD DO

An attacker uses the built-in Microsoft certificate utility (`certutil.exe`) to download a secondary payload (such as a remote access trojan, ransomware loader, or credential dumper) directly from a remote staging server into `%TEMP%`.

Because `certutil.exe` is signed by Microsoft and native to all modern Windows systems, living-off-the-land techniques bypass standard application-whitelisting policies and basic download filters. Once staged, the binary is executed to establish interactive C2 control.

WHAT TRIAGENT DID

Triagent investigated the certutil.exe download command line, queried process trees and historical events, and inspected the downloaded payload in the Temp directory. Because the simulated payload was a harmless text placeholder, signature analysis returned an error and VirusTotal had no malicious detection record, while the private IP address appeared internal. Consequently, the agent erroneously concluded that the download was benign without prompting the human operator, resulting in a false positive verdict on a true attack.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
57s	**133,530**	**$0.0534**

✗ **Outcome: No (Documented Miss)**

Documented miss. Triagent misclassified the ingress tool transfer as a false positive due to the harmless dummy payload and private staging IP, taking no containment action.

A3

Obfuscated PowerShell Download-and-Run

Sigma: Suspicious PowerShell Encoded Command Patterns (high) • 2 Alerts

`T1059.001` Command and Scripting Interpreter: PowerShell

`T1027` Obfuscated Files or Information

WHAT A REAL ATTACKER WOULD DO

An attacker launches PowerShell with a Base64-encoded command line (`-EncodedCommand`) to conceal execution details from casual monitoring and command-line logging. The encoded payload downloads an unsigned secondary PowerShell script directly into memory or disk and executes it immediately.

In an actual attack, the downloaded script typically establishes an encrypted remote shell or persistence mechanism to facilitate remote control.

WHAT TRIAGENT DID

This attack produced two separate alerts on the same encoded PowerShell command line, three minutes apart. The FIRST alert was investigated and closed as false_positive with high confidence, without asking the operator. The SECOND alert, on the same underlying activity, was investigated independently, recognized the obfuscated execution pattern, asked the operator to confirm, received a 'no, not authorized' response, and was correctly escalated to true_positive with an approved process kill. Because we score by the attack's primary (earliest) alert, and that alert returned false_positive, this attack is scored as a documented disagreement between alerts, not a clean pass — even though the correct verdict was reached three minutes later on a related alert.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
3m 17s	772,554	$0.3090

~ Outcome: Partial (Conflicting Alert Verdicts (Partial = 0.5))

Documented disagreement between alerts. The earliest alert was closed as a false positive, while the correlated pattern alert three minutes later correctly identified the attack, confirmed with the operator, and terminated the process.

A4

OS Credential Dumping via LSASS Memory

Sigma: Process Memory Dump Via Comsvcs.DLL (high) • 2 Alerts

`T1003.001` OS Credential Dumping: LSASS Memory

WHAT A REAL ATTACKER WOULD DO

An adversary executes `rundll32.exe comsvcs.dll, MiniDump` against the Local Security Authority Subsystem Service (`lsass.exe`) process memory to create a raw memory dump file (`lsass.dmp`).

Because LSASS caches active user credentials, NTLM password hashes, and Kerberos tickets in RAM, extracting this memory file enables offline recovery of administrative authentication credentials.

WHAT TRIAGENT DID

Both alerts independently classified the comsvcs.dll LSASS dump command as a true positive without needing to ask the operator. A kill was proposed and approved; by the time it ran, the short-lived rundll32 process had already exited on its own, so the first kill attempt returned 'already exited.' A second kill attempt on the same alert returned an error (process GUID not found), which we are documenting rather than smoothing over — it suggests a timing/reference issue in the response tool when a target has already exited, worth investigating further.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
47s	**94,605**	**$0.0378**

✓ Outcome: Yes (Matched Expected Verdict)

Both alerts were independently classified as true positive credential dumping attempts without human queries. Process termination was attempted after operator approval, but the short-lived rundll32 process had already exited, and a subsequent kill attempt returned an error.

A5

Inhibiting System Recovery (Shadow Copies Deletion)

Sigma: Shadow Copies Deletion Using Operating Systems Utilities (high) • 1 Alert

`T1490` Inhibit System Recovery `T1070` Indicator Removal

WHAT A REAL ATTACKER WOULD DO

An attacker invokes native Windows recovery management tools (`vssadmin.exe delete shadows /all /quiet`) to silently purge all Volume Shadow Copies and system restore points.

This behavior is a common precursor to ransomware deployment. By destroying local snapshots prior to file encryption, the attacker prevents victims from recovering their files using native Windows backup utilities.

WHAT TRIAGENT DID

Triagent reconstructed an elevated process tree where a persistent PowerShell session repeatedly created and executed a hidden script (backup-cleaner.ps1) to invoke vssadmin.exe with quiet shadow-copy deletion flags. The agent queried Exa technical intelligence and rule context to analyze the deletion pattern, requested operator authorization to terminate the active parent PowerShell session, and quarantined the malicious script file, delivering a high-confidence true positive verdict in under two minutes.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
`1m 54s`	`830,158`	`$0.3321`

✓ Outcome: Yes (Matched Expected Verdict)

Triagent successfully identified the ransomware precursor activity, terminated the live elevated PowerShell process upon operator approval, and quarantined the dropper script, completely remediating the active execution.

4. Section B — Benign Scenarios

B1

Indirect Command Execution via Pcalua (Calculator)

Sigma: Use of Pcalua For Execution (medium) • 1 Alert

`T1202` Indirect Command Execution

WHAT TRIAGENT DID

Triagent examined the execution of the Windows Program Compatibility Assistant (pcalua.exe) launching calc.exe. It verified that both executables were valid Microsoft-signed binaries, observed zero network connections or persistence artifacts, and asked the operator to confirm whether the calculator launch was intentional. Upon operator confirmation, it promptly submitted a false positive verdict.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
50s	150,513	$0.0602

✓ Outcome: Yes (Correctly Cleared as False Positive)

Correctly cleared. The agent recognized the benign nature of the dual-signed LOLBin process launch and verified user intent via a single HITL query.

B2

Administrative Encoded PowerShell Health Check

Sigma: Suspicious Encoded PowerShell Command Line (high) • 2 Alerts

`T1059.001` Command and Scripting Interpreter: PowerShell

WHAT TRIAGENT DID

Triagent inspected an encoded PowerShell command line, decoded the Base64 payload, and discovered a harmless maintenance string printing a system health status. In the primary alert investigation, the agent confirmed the absence of external network connections, persistence keys, or dropped files, clearing the alert as a false positive in 30 seconds without requiring human disruption.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
30s	202,436	$0.0810

✓ Outcome: Yes (Correctly Cleared as False Positive)

Correctly cleared. The agent decoded the administrative health check script and cleared the alert autonomously with zero human intervention in 30 seconds.

B3

Developer Pre-Flight Privilege Check (whoami /priv)

Sigma: Security Privileges Enumeration Via Whoami.EXE (high) • 1 Alert

`T1033` System Owner/User Discovery

WHAT TRIAGENT DID

Triagent investigated the execution of whoami.exe /priv launched from an administrative PowerShell terminal. The agent verified that whoami.exe was a genuine Microsoft-signed system executable with 0 detections on VirusTotal and confirmed no subsequent malicious commands or network traffic were generated. It verified the developer's pre-flight intent via a single HITL query and closed the alert as a false positive.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
48s	**244,379**	**$0.0978**

✓ Outcome: Yes (Correctly Cleared as False Positive)

Correctly cleared. The agent validated the developer privilege check through system telemetry and verified operator authorization before clearing the alert.

B4

Maintenance Scheduled Task Creation (Notepad Updater)

Sigma: Suspicious Schtasks Schedule Types (high) • 3 Alerts

`T1053.005` Scheduled Task/Job: Scheduled Task

WHAT TRIAGENT DID

Triagent investigated the creation of a one-time scheduled task (B4_AppUpdater) via schtasks.exe configured to execute notepad.exe. It verified that both schtasks.exe and notepad.exe were legitimate Microsoft-signed utilities, observed that the task was immediately removed after execution, and confirmed with the operator that the scheduled task was authorized maintenance, concluding false positive.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
52s	**290,793**	**$0.1163**

✓ Outcome: Yes (Correctly Cleared as False Positive)

Correctly cleared. All three generated alerts were confirmed as benign administrative maintenance tasks and safely cleared without escalation.

B5

Standard User Shell Folders Startup Configuration

Sigma: User Shell Folders Registry Modification via CommandLine (high) • 1 Alert

`T1547.001` Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder

WHAT TRIAGENT DID

Triagent inspected the modification of the User Shell Folders Startup registry key by reg.exe. Telemetry analysis revealed that the written value matched the standard Windows default %USERPROFILE% Startup path rather than an unauthorized or disguised executable. The agent verified the Microsoft digital signature of reg.exe, confirmed with the operator that the registry update was intentional, and designated the alert as a false positive.

TIME TO VERDICT	TOKEN CONSUMPTION	EXECUTION COST
52s	**265,787**	**$0.1063**

✓ Outcome: Yes (Correctly Cleared as False Positive)

Correctly cleared. The agent verified that the registry command only restored the legitimate operating system default startup directory and cleared the alert upon user confirmation.

5. Empirical Results & Performance Synthesis

The aggregate performance across all ten scenarios highlights Triagent's operational profile when deployed on Windows endpoints:

3.5 / 5 (70%)
ATTACK ACCURACY (PARTIAL = 0.5)

5 / 5 (100%)
BENIGN RESOLUTION (0 ESCALATED)

52.0s
MEDIAN TRIAGE TIME

$0.1358
AVERAGE COST / ALERT

SCENARIO ID	CATEGORY	EXPECTED	VERDICT	OUTCOME	TIME	TOKENS	COST (USD)
A1	Attack (Spearphishing Trojan Dropper (.pdf.exe))	True Positive	True Positive	Yes	3m	409,285	$0.1637
A2	Attack (Ingress Tool Transfer via Certutil)	True Positive	False Positive	No	57s	133,530	$0.0534
A3	Attack (Obfuscated PowerShell Download-and-Run)	True Positive	True Positive	Partial (0.5)	3m 17s	772,554	$0.3090
A4	Attack (OS Credential Dumping via LSASS Memory)	True Positive	True Positive	Yes	47s	94,605	$0.0378
A5	Attack (Inhibiting System Recovery (Shadow Copies Deletion))	True Positive	True Positive	Yes	1m 54s	830,158	$0.3321
B1	Benign (Indirect Command Execution via Pcalua (Calculator))	False Positive	False Positive	Yes	50s	150,513	$0.0602
B2	Benign (Administrative Encoded PowerShell Health Check)	False Positive	False Positive	Yes	30s	202,436	$0.0810
B3	Benign (Developer Pre-Flight Privilege Check (whoami /priv))	False Positive	False Positive	Yes	48s	244,379	$0.0978
B4	Benign (Maintenance Scheduled Task Creation (Notepad Updater))	False Positive	False Positive	Yes	52s	290,793	$0.1163
B5	Benign (Standard User Shell Folders Startup Configuration)	False Positive	False Positive	Yes	52s	265,787	$0.1063

Engineering Observations: What Could Get Better

- **Handling Non-Executable Payloads (A2):** When `get_file_signature` returned `UnknownError` on a plain-text placeholder downloaded via `certutil.exe`, the agent assumed it was harmless. Dropper downloads from direct IP addresses must default to high suspicion regardless of file extension or preliminary signature validity.
- **Internal vs External IP Heuristics (A2):** The test staging server utilized a loopback/private IP (`127.0.0.1`), which biased the agent toward assuming an internal authorized tool. Future revisions will flag living-off-the-land file transfers regardless of address locality.
- **Correlated Rule Disagreement (A3):** An initial alert for an encoded command line was cleared as benign before a secondary pattern alert correctly escalated it. Cross-alert session memory should propagate context across contemporaneous alerts from the same process lineage.
- **Timing and Process Lifespan in Remediation (A4):** When attempting process termination on ultra-short-lived LOLBins (such as `rundll32.exe comsvcs.dll`), the target process had already exited before the containment command was dispatched. Furthermore, a secondary kill attempt returned a reference error (`Process GUID was not found in event history`). Response tools must gracefully handle race conditions when target processes terminate prior to containment execution.
- **Workspace Boundary Protections (A3):** Containment actions safely refrained from deleting files located in the project root. While essential for development safety, production deployments require clear quarantine escalation paths for user workspace directories.

6. Limitations & Acknowledgments

Limitations: This benchmark relies on 10 targeted test runs executed on a single host. Attack scenarios were intentionally selected from techniques with established Sigma detection coverage to assess investigation, enrichment, and containment rather than raw sensor sensitivity. Real-world adversaries employ multi-stage evasions, delayed persistence, and lateral movement that may alter token consumption and investigation duration.

Acknowledgments: We gratefully acknowledge the open-source detection engineering community, specifically **SigmaHQ** for the detection rule taxonomy, the **Atomic Red Team** project by Red Canary for behavioral simulation paradigms, and Microsoft for Sysmon endpoint telemetry.